Microsoft 365 Security Baseline & Audit Readiness (Secure Score / Compliance Manager)

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — Microsoft 365 Security Baseline & Audit Readiness 4

What you get . . . 4

What this delivers . . . 4

The Phoenixtekk deployment model . . . 4

Outcome . . . 4

1. Solution Overview — Microsoft 365 Security Baseline & Audit Readiness 5

What this solution is . . . 5

Why this matters (the why lives here, and only here) . . . 5

How it works . . . 5

What you can control . . . 6

Limitations (be honest with buyers) . . . 6

The standard Phoenixtekk deployment model . . . 6

2. Requirements Guide — Microsoft 365 Security Baseline & Audit Readiness 6

2.1 Microsoft 365 subscription with security workloads . . . 6

2.2 Security / compliance licensing for Secure Score and Compliance Manager . . . 7

2.3 Administrative roles . . . 7

2.4 A named target framework . . . 7

2.5 A baseline owner and change control . . . 7

2.6 A pilot scope group . . . 7

2.7 Microsoft Graph PowerShell for discovery and reporting . . . 8

Checklist . . . 8

3. Implementation Guide — Microsoft 365 Security Baseline & Audit Readiness 8

Step 1 — Create the scope groups . . . 8

Step 2 — Assess the current posture (Secure Score + config) . . . 8

Step 3 — Configure identity to the baseline . . . 9

Step 4 — Configure email protection (Exchange Online Protection) . . . 9

Step 5 — Configure collaboration (sharing and guest access) . . . 9

Step 6 — Configure device and data posture . . . 9

Step 7 — Map controls in Compliance Manager . . . 10

Step 8 — Capture control evidence . . . 10

Step 9 — Validate the pilot . . . 10

Step 10 — Expand and set the review cadence . . . 10

5. Testing Guide — Microsoft 365 Security Baseline & Audit Readiness 11

Test 1 — Baseline captured . . . 11

Test 2 — Secure Score measured and improving . . . 11

Test 3 — Baseline compliance . . . 11
Test 4 — Identity posture . . . 11
Test 5 — Email protection active (EOP) . . . 11
Test 6 — Collaboration posture . . . 11
Test 7 — Controls mapped and evidenced . . . 11
Pass/fail gate . . . 12
6. Troubleshooting Guide — Microsoft 365 Security Baseline & Audit Readiness 12
A. Secure Score not improving . . . 12
B. Baseline compliance gaps . . . 12
C. Compliance Manager assessment issues . . . 13
D. Evidence pack incomplete . . . 13
E. Pilot breakage (sign-in / mail / sharing) . . . 13
F. Graph / permissions problems . . . 13
G. When to escalate . . . 13
7. Best Practices — Microsoft 365 Security Baseline & Audit Readiness 14
8. Deliverables Summary — Microsoft 365 Security Baseline & Audit Readiness 14
Documentation . . . 14
PowerShell scripts . . . 15
Named objects (reused verbatim) . . . 15
What the buyer receives . . . 15
Outcome . . . 15
Appendix A — PowerShell Scripts 17

Executive Summary — Microsoft 365 Security Baseline & Audit Readiness

Phoenixtekk Workplace Marketplace · Security

Most Microsoft 365 tenants are configured to "it works", not "it's secure" — and when an audit or a framework assessment lands, nobody can show the controls are actually in place. This solution delivers a repeatable Microsoft 365 security baseline and audit-readiness program: harden the tenant and its services to a documented baseline (raising Microsoft Secure Score), map the controls to a recognized framework with Microsoft Purview Compliance Manager, and maintain the control evidence so audit readiness is continuous, not a fire drill.

This is a complete, deploy-it-today package written for an administrator with no prior tenant-hardening or audit-evidence experience.

What you get

- A plain-language Solution Overview of the M365 secure-configuration baseline across identity, email, collaboration, device, and data services, plus Secure Score, Compliance Manager, and the control-evidence model.
- A Requirements Guide with verify / implement-if-missing for every prerequisite.
- An Implementation Guide of precise, ordered steps to assess, configure, map, evidence, validate, and maintain the baseline.
- Five PowerShell scripts for Secure Score + service-config discovery, baseline-compliance validation, a Secure Score + control-evidence report, safe remediation of baseline gaps, and a baseline-scope group builder.
- Testing and Troubleshooting guides for a confident rollout.

What this delivers

A Microsoft 365 tenant hardened to a documented baseline, an improving Secure Score, controls mapped to your target framework in Compliance Manager, and a maintained evidence pack — so the next audit is a report you hand over, not a scramble you dread.

The Phoenixtekk deployment model

Assess to Configure to Pilot to Validate to Expand.

Outcome

A hardened, mapped, and evidenced Microsoft 365 tenant — proven on a pilot scope before you expand it across every service — deployable by a single administrator and repeatable on a review cadence.

1. Solution Overview — Microsoft 365 Security Baseline & Audit Readiness

What this solution is

This is a Microsoft 365 tenant and service secure-configuration baseline, plus the audit-evidence program that goes with it. It hardens the settings that govern identity, email (Exchange Online Protection), collaboration (Teams / SharePoint / OneDrive), device, and data services to a single documented baseline; it measures and improves that posture with Microsoft Secure Score; and it maps the resulting controls to a recognized framework in Microsoft Purview Compliance Manager, capturing the control evidence an auditor asks for.

This is the tenant/service layer, and is deliberately distinct from CIS/STIG endpoint hardening (which secures the operating system on each device). Here the object being hardened is the Microsoft 365 tenant and its cloud services.

Why this matters (the why lives here, and only here)

A tenant that "works" is not a tenant that is secure. Defaults leave gaps — legacy authentication enabled, weak external sharing, no baseline for admin roles — and those gaps are exactly what a framework assessment or a breach investigation surfaces. Worse, even a well-configured tenant fails an audit if nobody can produce evidence that the control is in place and stays in place. This solution fixes both problems at once: it raises the actual security posture (measurable as Secure Score) and it produces the durable, mapped, dated evidence that turns an audit from a fire drill into a report.

How it works

1. A baseline register — the object named `M365 Security Baseline Register – Tenant Services – Baseline` — records every target setting across identity, email, collaboration, device, and data services, with its desired value and rationale.

1. Microsoft Secure Score (`security.microsoft.com` to Secure Score) measures current posture against Microsoft's recommended actions; each improvement action raises the score and maps to one or more baseline settings.

1. The tenant and services are configured to the baseline in the admin centers (Entra, Exchange, Teams/SharePoint, Intune, Purview), then piloted against a scope group before expansion.

1. Microsoft Purview Compliance Manager (`purview.microsoft.com` to Compliance Manager) holds an assessment — the object named `Compliance Assessment – Target Framework – Mapping` — that maps improvement actions to the controls of a recognized framework and tracks implementation and test status.

1. Control evidence (screenshots, exported settings, script output) is captured into the object named `Control Evidence Pack – Tenant Baseline – Audit`, dated and tied to each control.

1. The baseline is re-validated on a review cadence so posture and evidence stay current.

What you can control

• Identity: legacy-auth block, security defaults / Conditional Access posture, admin-role baseline.

• Email (Exchange Online Protection): anti-malware, anti-phish, anti-spam, and Safe Attachments / Safe Links preset security policies.

• Collaboration: external sharing posture for SharePoint / OneDrive and Teams guest access.

• Device and data: compliance-policy baseline signals and data-protection / DLP posture.

• Measurement and mapping: Secure Score targets and the Compliance Manager framework assessment.

• Evidence: what is captured, when, and against which control.

Limitations (be honest with buyers)

• This baselines the M365 tenant and services; it does not harden the endpoint OS (that is the CIS/STIG endpoint baseline, a separate solution).

• Compliance Manager assessment templates and some improvement actions depend on your security/compliance licensing (E5 / compliance add-ons unlock more).

• Secure Score reflects Microsoft-defined recommended actions; it is a strong measure, not a certification, and should be paired with the framework assessment.

• Framework mapping supports the audit; the auditor of record still issues the finding.

The standard Phoenixtekk deployment model

> *Record the baseline register to assess Secure Score and current config, configure services to the baseline, pilot against a scope group, validate, then expand — mapping controls in Compliance Manager and capturing evidence throughout. Phoenixtekk pattern: Assess to Configure to Pilot to Validate to Expand, on a review cadence.*

2. Requirements Guide — Microsoft 365 Security Baseline & Audit Readiness

Verify every requirement before configuring. Each entry: Description · Why · Verify · Implement-if-missing. Category-wide prerequisites are in `global-requirements-security.md`.

2.1 Microsoft 365 subscription with security workloads

Description: A Microsoft 365 tenant with Entra ID, Exchange Online, and the collaboration services (Teams / SharePoint / OneDrive) active. **Why:** The baseline hardens these services, so they must exist to configure. **Verify:** `https://admin.microsoft.com` to Billing to Licenses shows an M365 plan; the

service health for Exchange, SharePoint, and Teams is active. **Implement:** Assign Microsoft 365 Business Premium, E3, or E5 (or the relevant standalone plans).

2.2 Security / compliance licensing for Secure Score and Compliance Manager

Description: Licensing that surfaces Microsoft Secure Score and Microsoft Purview Compliance Manager (Compliance Manager is included at a baseline level; premium assessment templates need E5 / compliance add-ons). **Why:** Secure Score measures posture and Compliance Manager holds the framework assessment and improvement actions. **Verify:** `https://security.microsoft.com` to Secure Score loads; `https://purview.microsoft.com` to Compliance Manager loads and shows assessment templates. **Implement:** Ensure E3/E5 or the compliance add-on is assigned so the required assessment templates are available.

2.3 Administrative roles

Description: Least-privilege admin roles for the operator (Security Administrator plus the service admin roles needed to change config, e.g. Exchange Administrator, SharePoint Administrator). **Why:** Configuring the baseline and running the assessment requires elevated, scoped rights; Global Administrator is reserved for tenant-wide changes. **Verify:** Entra to Roles and administrators; confirm Security Administrator and the relevant service-admin roles. **Implement:** Assign Security Administrator and the specific service-admin roles; avoid granting Global Administrator broadly.

2.4 A named target framework

Description: The recognized framework (or frameworks) the tenant is being assessed against, so Compliance Manager maps to the right controls. **Why:** Controls, evidence, and improvement actions are mapped to a specific framework; without a named target the mapping is undirected. **Verify:** The framework is documented in the baseline register and an assessment template for it exists in Compliance Manager. **Implement:** Confirm the target framework with the audit sponsor, then select its assessment template in Compliance Manager (Requirement 2.2 gates availability).

2.5 A baseline owner and change control

Description: A named owner accountable for the baseline register and a change-control / rollback process for security-impacting changes. **Why:** Baseline changes can affect sign-in, mail flow, and sharing; a pilot gate and rollback are mandatory, and the owner keeps the register authoritative. **Verify:** The baseline register names an owner; a change ticket with approver, window, and rollback exists for baseline changes. **Implement:** Assign the owner; adopt the change-control process from `global-requirements-security.md`.

2.6 A pilot scope group

Description: A Microsoft Entra security group scoping the pilot population for scoped-configuration changes (e.g. Conditional Access, DLP). **Why:** Every change is piloted before tenant-wide expansion — especially anything touching sign-in or mail flow. **Verify:** Entra to Groups; the pilot scope group exists — run `M365SEC-Set-ScopeTargeting.ps1`. **Implement:** Create the scope groups with

`M365SEC-Set-ScopeTargeting.ps1` (or Entra to Groups to New group).

2.7 Microsoft Graph PowerShell for discovery and reporting

Description: The Microsoft Graph PowerShell SDK on the operator workstation, with consent to the read scopes the scripts use. **Why:** The discovery, validation, and report scripts read Secure Score, secure-score control profiles, and service configuration via Microsoft Graph. **Verify:** `Get-Module -ListAvailable Microsoft.Graph.Authentication` returns a version; run `M365SEC-Discovery.ps1`. **Implement:** `Install-Module Microsoft.Graph -Scope CurrentUser`; consent to the read scopes on first connect.

Checklist

- Microsoft 365 subscription with Entra / Exchange / collaboration services
- Security / compliance licensing for Secure Score + Compliance Manager
- Least-privilege admin roles (Security Administrator + service admins)
- A named target framework
- A baseline owner and change control
- Pilot scope group — `M365SEC-Set-ScopeTargeting.ps1`
- Microsoft Graph PowerShell installed — `M365SEC-Discovery.ps1`

3. Implementation Guide — Microsoft 365 Security Baseline & Audit Readiness

Follow these steps in order, across the Microsoft 365 admin centers. The steps produce three named objects you will reuse verbatim throughout: the baseline register (`M365 Security Baseline Register – Tenant Services – Baseline`), the Compliance Manager assessment (`Compliance Assessment – Target Framework – Mapping`), and the evidence pack (`Control Evidence Pack – Tenant Baseline – Audit`).

> ***Model:*** *Assess current posture, configure the services to the baseline, pilot against a scope group, validate, then expand — mapping controls and capturing evidence as you go. Assess to Configure to Pilot to Validate to Expand.*

Step 1 — Create the scope groups

1. Run `M365SEC-Set-ScopeTargeting.ps1 -Apply` to create the baseline scope groups (`M365 Baseline Scope – Pilot – Users` and `M365 Baseline Scope – Broad – Users`), or create them in Entra to Groups to New group to Security.
1. Add a small, representative pilot population to `M365 Baseline Scope – Pilot – Users`.

Step 2 — Assess the current posture (Secure Score + config)

1. Go to `https://security.microsoft.com` to Secure Score and record the current score and the top

recommended actions.

1. Run `M365SEC-Discovery.ps1` to capture the current Secure Score, the secure-score control

profiles, and the key service configuration read via Microsoft Graph.

1. Record every target setting, its current value, and its desired value in the baseline register

(`M365 Security Baseline Register – Tenant Services – Baseline`).

Step 3 — Configure identity to the baseline

1. Entra admin center (`https://entra.microsoft.com`): block legacy authentication and confirm the

Conditional Access / security-defaults posture in the baseline register.

1. Apply the admin-role baseline (least privilege; reserve Global Administrator).

2. For scoped Conditional Access, target `M365 Baseline Scope – Pilot – Users` first.

3. Capture the resulting settings into the evidence pack (`Control Evidence Pack – Tenant Baseline – Audit`).

Step 4 — Configure email protection (Exchange Online Protection)

1. `https://security.microsoft.com` to Email & collaboration to Policies & rules to Threat policies.

2. Apply the preset security policies (anti-malware, anti-phish, anti-spam, Safe Attachments, Safe

Links) to the baseline, scoping the pilot to `M365 Baseline Scope – Pilot – Users` where the policy supports scoping.

1. Capture the policy settings into the evidence pack.

Step 5 — Configure collaboration (sharing and guest access)

1. SharePoint admin center: set the external-sharing posture per the baseline register.

2. Teams admin center: set guest-access and external-access posture per the baseline register.

3. Capture the sharing/guest settings into the evidence pack.

Step 6 — Configure device and data posture

1. Intune (`https://intune.microsoft.com`): confirm the compliance-policy baseline signals used by

the baseline register.

1. Purview (`https://purview.microsoft.com`): set the data-protection / DLP posture per the baseline

register, scoping DLP pilots to `M365 Baseline Scope – Pilot – Users` where supported.

1. Capture the device/data settings into the evidence pack.

Step 7 — Map controls in Compliance Manager

1. `https://purview.microsoft.com` to Compliance Manager to Assessments to Add assessment.

2. Select the assessment template for your target framework and name the assessment `Compliance Assessment – Target Framework – Mapping`.

1. Work the improvement actions: mark each Microsoft-managed and customer-managed action against the

baseline settings you configured in Steps 3 to 6, and set implementation and test status.

Step 8 — Capture control evidence

1. Run `M365SEC-Report.ps1` to produce the Secure Score summary and the control-evidence report.

2. File the report, exported settings, and screenshots into the evidence pack (`Control Evidence Pack – Tenant Baseline – Audit`), dated and tied to each control / improvement action.

Step 9 — Validate the pilot

1. Run `M365SEC-Validation.ps1` to confirm the tenant matches the baseline register (baseline compliance).

1. Confirm sign-in, mail flow, and sharing still work for the pilot population; complete the Testing Guide.

1. Remediate any baseline gaps with `M365SEC-Remediation.ps1` (defaults to `-WhatIf`; re-run with `-Apply` after review).

Step 10 — Expand and set the review cadence

1. Once the pilot validates, expand scoped changes from `M365 Baseline Scope – Pilot – Users` to

`M365 Baseline Scope – Broad – Users` (and tenant-wide where the setting is tenant-scoped).

1. Set a review cadence (e.g. monthly Secure Score review, quarterly baseline re-validation) and re-run `M365SEC-Validation.ps1` and `M365SEC-Report.ps1` each cycle to keep posture and evidence current.

Order of operations

`Scope groups → Assess (Secure Score + Discovery) → Identity → Email (EOP) → Collaboration → Device/Data → Map in Compliance Manager → Capture evidence → Validate pilot → Expand + review cadence`

5. Testing Guide — Microsoft 365 Security Baseline & Audit Readiness

Run after the pilot configuration applies (Implementation Step 9) and after each review cycle.

Test 1 — Baseline captured

Do: Run `M365SEC-Discovery.ps1` and confirm the baseline register (`M365 Security Baseline Register – Tenant Services – Baseline`) records each target setting's current and desired value. **Expected:** Every baseline setting has a recorded current value and a desired value.

Test 2 — Secure Score measured and improving

Do: `https://security.microsoft.com` to Secure Score; compare with the pre-configuration score recorded in Step 2. **Expected:** The score has improved and the configured improvement actions show as completed / in-progress.

Test 3 — Baseline compliance

Do: Run `M365SEC-Validation.ps1`. **Expected:** The tenant matches the baseline register; deviations are listed as explicit gaps.

Test 4 — Identity posture

Do: Confirm legacy authentication is blocked and the Conditional Access / admin-role baseline is in place for the pilot scope. **Expected:** Legacy auth blocked; scoped policies applied to `M365 Baseline Scope – Pilot – Users`; sign-in still works for pilot users.

Test 5 — Email protection active (EOP)

Do: Confirm the anti-malware / anti-phish / anti-spam / Safe Attachments / Safe Links preset policies are applied and mail flow is healthy for the pilot. **Expected:** Preset security policies enabled per the baseline; legitimate mail still delivers.

Test 6 — Collaboration posture

Do: Confirm SharePoint/OneDrive external-sharing and Teams guest-access settings match the baseline register. **Expected:** Sharing/guest posture matches the baseline; expected collaboration still works.

Test 7 — Controls mapped and evidenced

Do: In Compliance Manager confirm `Compliance Assessment – Target Framework – Mapping` shows the improvement actions worked; run `M365SEC-Report.ps1` and confirm the evidence pack

(`Control Evidence Pack – Tenant Baseline – Audit`) has dated evidence per control. **Expected:** Improvement actions have implementation/test status; each control has current, dated evidence.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1 to 6 pass; Secure Score improved; no loss of sign-in, mail, or sharing for the pilot
Audit pass	Test 7 passes; controls mapped in Compliance Manager with current, dated evidence

6. Troubleshooting Guide — Microsoft 365 Security Baseline & Audit Readiness

Use `M365SEC-Discovery.ps1` / `M365SEC-Validation.ps1` for posture and baseline state, `M365SEC-Report.ps1` for the Secure Score + control-evidence report, and `M365SEC-Remediation.ps1` (default `-WhatIf`) for safe fixes.

A. Secure Score not improving

Symptom	Cause	Remediation
Score unchanged after config	Improvement action not the one measured, or score not yet refreshed	Confirm which recommended action maps to the setting in `security.microsoft.com` to Secure Score; scores refresh on Microsoft's cadence, not instantly
Action shows not completed	Setting applied at wrong scope or partially	Re-run `M365SEC-Validation.ps1`; confirm the setting is applied tenant-wide or to the intended scope group

B. Baseline compliance gaps

Symptom	Cause	Remediation
Validation lists deviations	Service not yet configured to the desired value	Configure the setting per the baseline register, then re-run `M365SEC-Validation.ps1`; use `M365SEC-Remediation.ps1 -WhatIf` to preview a safe fix

Symptom	Cause	Remediation
Setting reverts	A conflicting policy or a second admin change	Identify the conflicting policy; make the baseline register the single source of truth and re-apply

C. Compliance Manager assessment issues

Symptom	Cause	Remediation
Target framework template missing	Licensing does not include the premium assessment template	Confirm E5 / compliance add-on (Requirement 2.2); use the included baseline template until licensed
Improvement action stuck at not implemented	Evidence/status not recorded	Work the action in `Compliance Assessment – Target Framework – Mapping`; set implementation and test status and attach evidence

D. Evidence pack incomplete

- Capture evidence at the moment of change, not at audit time; run `M365SEC-Report.ps1` each review

cycle and file dated output into `Control Evidence Pack – Tenant Baseline – Audit` tied to each control.

E. Pilot breakage (sign-in / mail / sharing)

- If a scoped change blocks pilot users, narrow or roll back the scoped policy per the change-control

rollback step, confirm the pilot works, then re-apply. Keep all scoped pilots on `M365 Baseline Scope – Pilot – Users` so blast radius stays small.

F. Graph / permissions problems

- If a script cannot read Secure Score or config, confirm the Microsoft Graph SDK is installed and

consent was granted to the read scopes; sign in with an account holding Security Reader / Security Administrator. Re-run `M365SEC-Discovery.ps1`.

G. When to escalate

If Secure Score and baseline validation both look correct but a framework control still shows a gap, export the control-evidence report and the assessment status and raise it with the auditor of record (or open a Microsoft support case for a Compliance Manager data issue).

7. Best Practices — Microsoft 365 Security Baseline & Audit Readiness

• **Write the baseline down.** A documented baseline register (`M365 Security Baseline Register – Tenant Services – Baseline`) with a desired value and rationale per setting is what makes the posture repeatable and auditable — not tribal knowledge.

• **Pilot every change.** Scope Conditional Access, DLP, and preset policies to `M365 Baseline Scope – Pilot – Users` first; sign-in, mail flow, and sharing are easy to break tenant-wide.

• **Measure with Secure Score, don't stop there.** Use Secure Score to drive and track improvement, but pair it with the Compliance Manager framework assessment — the score is a measure, the assessment is the mapping an auditor reads.

• **Map controls once, maintain forever.** Keep `Compliance Assessment – Target Framework – Mapping` current so improvement-action status reflects reality instead of drifting.

• **Capture evidence as you configure.** File dated evidence into `Control Evidence Pack – Tenant Baseline – Audit` at the moment you make each change; reconstructing evidence at audit time is the fire drill this solution exists to remove.

• **Least privilege for operators.** Use Security Administrator plus scoped service-admin roles; reserve Global Administrator for genuinely tenant-wide changes.

• **One baseline owner.** A named owner keeps the register authoritative and prevents silent drift.

• **Re-validate on a cadence.** Run `M365SEC-Validation.ps1` and `M365SEC-Report.ps1` on a set schedule so posture and evidence stay current between audits.

• **Remediate safely.** Run `M365SEC-Remediation.ps1` in its default `-WhatIf` mode, review the proposed changes, then apply — never blind-apply security changes.

• **Keep this distinct from endpoint hardening.** This baselines the M365 tenant/service layer; the CIS/STIG endpoint baseline is a separate control set — track them separately so neither hides gaps in the other.

8. Deliverables Summary — Microsoft 365 Security Baseline & Audit Readiness

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box

Document	Purpose
1. Solution Overview	The M365 secure-configuration baseline, Secure Score, Compliance Manager, and the control-evidence model
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing
Global Requirements (Security)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps: assess, configure services, map controls, capture evidence, validate, expand
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations

PowerShell scripts

Script	What it does
`M365SEC-Discovery.ps1`	Reads Secure Score, secure-score control profiles, and key service configuration (read-only)
`M365SEC-Validation.ps1`	Confirms the tenant matches the baseline register (baseline compliance, read-only)
`M365SEC-Report.ps1`	Secure Score summary + control-evidence report for the evidence pack (read-only)
`M365SEC-Remediation.ps1`	Safe remediation of baseline gaps; defaults to `-WhatIf`
`M365SEC-Set-ScopeTargeting.ps1`	Creates the baseline scope groups (pilot / broad)

Named objects (reused verbatim)

- `M365 Security Baseline Register – Tenant Services – Baseline`
- `Compliance Assessment – Target Framework – Mapping`
- `Control Evidence Pack – Tenant Baseline – Audit`
- `M365 Baseline Scope – Pilot – Users` and `M365 Baseline Scope – Broad – Users`

What the buyer receives

- This implementation guide as a branded Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable process following the Phoenixtekk model: Assess to Configure to Pilot to Validate to Expand, on a review cadence.

Outcome

A Microsoft 365 tenant hardened to a documented baseline with an improving Secure Score, controls mapped to your framework, and evidence maintained — so audits are a report, not a fire drill.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

M365SEC-Discovery.ps1

Purpose: Reads the tenant's current Microsoft Secure Score and the secure-score control profiles, plus the key organization/service configuration signals used by the baseline register (organization info and, where available, security-related settings), so you can record the current posture in the baseline register before you configure anything. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\M365SEC-Discovery.ps1 Requires the Microsoft Graph PowerShell SDK and consent to: SecurityEvents.Read.All, Organization.Read.All, Directory.Read.All. EXPECTED RESULTS The latest Secure Score (current / max / percentage), the top control profiles with their implementation state, and basic organization/service configuration — printed so you can transcribe each into the baseline register 'M365 Security Baseline Register - Tenant Services - Baseline'. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Uses documented endpoints: /security/secureScores, /security/secureScoreControlProfiles, /organization. Product/service-specific deep config is captured via the admin centers per the Implementation Guide. #> [CmdletBinding()] param()

How to run: powershell -ExecutionPolicy Bypass -File .\M365SEC-Discovery.ps1 Requires the Microsoft Graph PowerShell SDK and consent to: SecurityEvents.Read.All, Organization.Read.All, Directory.Read.All. EXPECTED RESULTS The latest Secure Score (current / max / percentage), the top control profiles with their implementation state, and basic organization/service configuration — printed so you can transcribe each into the baseline register 'M365 Security Baseline Register - Tenant Services - Baseline'. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Uses documented endpoints: /security/secureScores, /security/secureScoreControlProfiles, /organization. Product/service-specific deep config is captured via the admin centers per the Implementation Guide. #> [CmdletBinding()] param()

M365SEC-Remediation.ps1

Purpose: Takes the baseline gaps identified by M365SEC-Validation.ps1 and applies the safe, well-understood configuration fixes that bring the tenant back to the baseline register 'M365 Security Baseline Register - Tenant Services - Baseline'. Safe by default: it runs in -WhatIf mode and only reports what it WOULD change; pass -Apply to actually make changes. Each change is scoped and reversible per your change-control process. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\M365SEC-Remediation.ps1 Apply after review: ... .\M365SEC-Remediation.ps1 -Apply With your baseline register: ... .\M365SEC-Remediation.ps1 -BaselinePath .\baseline-register.json -Apply Requires the Microsoft Graph PowerShell SDK and consent to the write scopes for the settings you remediate (e.g. Policy.ReadWrite.ConditionalAccess) — granted on connect. EXPECTED RESULTS In preview mode: a list of the changes that WOULD be made per baseline gap, and nothing is altered. In -Apply mode: the same list, with each supported change applied and confirmed. .NOTES White-label — the repeatable way. SAFE BY DEFAULT (-WhatIf). Never blind-apply security changes; review the preview, confirm the change-control ticket and rollback, then -Apply. Changes that require an admin-center action (no supported Graph write) are reported as MANUAL with the exact navigation, rather than attempted. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([string]$BaselinePath, [switch]$Apply)

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\M365SEC-Remediation.ps1 Apply after review: ... .\M365SEC-Remediation.ps1 -Apply With your baseline register: ... .\M365SEC-Remediation.ps1 -BaselinePath .\baseline-register.json -Apply Requires the Microsoft Graph PowerShell SDK and consent to the write scopes for the settings you remediate (e.g. Policy.ReadWrite.ConditionalAccess) — granted on connect. EXPECTED RESULTS In preview mode: a list of the changes that WOULD be made per baseline gap, and nothing is altered. In -Apply mode: the same list, with each supported change applied and confirmed. .NOTES White-label — the repeatable way. SAFE BY DEFAULT (-WhatIf). Never blind-apply security changes; review the preview, confirm the change-control ticket and rollback, then -Apply. Changes that require an admin-center action (no supported Graph write) are reported as MANUAL with the exact navigation, rather than attempted. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([string]$BaselinePath, [switch]$Apply)

M365SEC-Report.ps1

Purpose: Produces the audit-facing report: the current Microsoft Secure Score with trend, and a control-evidence table listing each Secure Score control, its category, max score, and current implementation status. Exports to CSV/HTML so the output can be filed, dated, into the evidence pack 'Control Evidence Pack - Tenant Baseline - Audit', tied to each control / improvement action. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\M365SEC-Report.ps1 -OutputFolder .\evidence Requires the Microsoft Graph PowerShell SDK and consent to: SecurityEvents.Read.All. EXPECTED RESULTS A console summary plus, in the output folder, dated files: SecureScore-Trend-.csv (score history) Control-Evidence-.csv (per-control status) Control-Evidence-.html (readable evidence table) File these into the evidence pack against the mapped controls. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Uses /security/secureScores (history + latest controlScores) and /security/secureScoreControlProfiles (control metadata). #> [CmdletBinding()] param([string]$OutputFolder = (Join-Path (Get-Location) 'evidence'))

How to run: powershell -ExecutionPolicy Bypass -File .\M365SEC-Report.ps1 -OutputFolder .\evidence Requires the Microsoft Graph PowerShell SDK and consent to: SecurityEvents.Read.All. EXPECTED RESULTS A console summary plus, in the output folder, dated files: SecureScore-Trend-<date>.csv (score history) Control-Evidence-<date>.csv (per-control status) Control-Evidence-<date>.html (readable evidence table) File these into the evidence pack against the mapped controls. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Uses /security/secureScores (history + latest controlScores) and /security/secureScoreControlProfiles (control metadata). #> [CmdletBinding()] param([string]$OutputFolder = (Join-Path (Get-Location) 'evidence'))

M365SEC-Set-ScopeTargeting.ps1

Purpose: Creates (idempotently) the Entra security groups used to scope the Microsoft 365 baseline pilot and expansion, following the solution naming convention so scoped policies (Conditional Access, DLP, preset security policies) can be assigned consistently: M365 Baseline Scope - Pilot - Users M365 Baseline Scope - Broad - Users Existing groups (matched by displayName) are reused, not duplicated. Members are NOT added — add pilot users by hand or via dynamic rules per your standard. HOW TO RUN Report only (default, safe): powershell -ExecutionPolicy Bypass -File .\M365SEC-Set-ScopeTargeting.ps1 Apply: ... .\M365SEC-Set-ScopeTargeting.ps1 -Apply Requires the Microsoft Graph SDK and Group.ReadWrite.All. EXPECTED RESULTS The two scope groups exist (created if missing, reused if present), with their object IDs printed for use in the scoped-policy assignments in the Implementation Guide. .NOTES White-label — the repeatable way. Safe by default (-WhatIf); pass -Apply to create groups.

#> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([switch]$Apply)

How to run: Report only (default, safe): powershell -ExecutionPolicy Bypass -File .\M365SEC-Set-ScopeTargeting.ps1 Apply: ... .\M365SEC-Set-ScopeTargeting.ps1 -Apply Requires the Microsoft Graph SDK and Group.ReadWrite.All. EXPECTED RESULTS The two scope groups exist (created if missing, reused if present), with their object IDs printed for use in the scoped-policy assignments in the Implementation Guide. .NOTES White-label — the repeatable way. Safe by default (-WhatIf); pass -Apply to create groups. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([switch]$Apply)

M365SEC-Validation.ps1

Purpose: Reads the current Secure Score control profiles and their implementation status and compares them against the desired-state baseline recorded in the baseline register 'M365 Security Baseline Register - Tenant Services - Baseline'. Reports each baseline item as MATCH or GAP so you can see exactly where the tenant diverges from the baseline before an audit. Read-only. HOW TO RUN Default (uses the bundled sample baseline): powershell -ExecutionPolicy Bypass -File .\M365SEC-Validation.ps1 With your own baseline (a JSON array of { controlId; desiredState }): ... .\M365SEC-Validation.ps1 -BaselinePath .\baseline-register.json Requires the Microsoft Graph PowerShell SDK and consent to: SecurityEvents.Read.All. EXPECTED RESULTS A per-control MATCH / GAP list and a summary count. GAP lines are the remediation backlog to work through in the Implementation Guide (and safely via M365SEC-Remediation.ps1). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. The baseline register is intentionally external (a JSON file you own); the bundled sample lists a few representative controls so the script runs out-of-the-box. #> [CmdletBinding()] param([string]$BaselinePath)

How to run: Default (uses the bundled sample baseline): powershell -ExecutionPolicy Bypass -File .\M365SEC-Validation.ps1 With your own baseline (a JSON array of { controlId; desiredState }): ... .\M365SEC-Validation.ps1 -BaselinePath .\baseline-register.json Requires the Microsoft Graph PowerShell SDK and consent to: SecurityEvents.Read.All. EXPECTED RESULTS A per-control MATCH / GAP list and a summary count. GAP lines are the remediation backlog to work through in the Implementation Guide (and safely via M365SEC-Remediation.ps1). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. The baseline register is intentionally external (a JSON file you own); the bundled sample lists a few representative controls so the script runs out-of-the-box. #> [CmdletBinding()] param([string]$BaselinePath)